

- Filename: comptia-pentest-plus-pt0-002-3-16-1-cloud-attacks.md
- Show Name: Pentest+ (PT0-002)
- Topic Name: Attacks and Exploits
- Episode Name: Cloud Attacks

Cloud Attacks

Objectives:

- List and describe common vulnerabilities, tools, and attacks leveraged against cloud services
-

- **Vulnerabilities**

- Misconfigured Cloud Assets
 - IAM
 - Federation Misconfigurations
 - Object Storage (S3)
 - Misconfigured permissions
 - Upload/Download
 - Public Read
 - Directory listing

- **Attacks**

- Credential Harvesting

- Grabbing creds any which way you can
 - Phishing
 - Social Engineering
 - Brute-Force
 - Malware
 - Dark Web

- Account Takeover

- Use the creds
 - Login and act as user
 - Auth portal
 - SSH
 - API

- Priv Esc

- Gaining access to other accounts / services
 - Horizontal/Vertical

- Metadata Service Attack

- <https://www.pumascan.com/resources/cloud-security-instance-metadata/>
- <https://www.mcafee.com/blogs/enterprise/cloud-security/how-an-attacker-could-use-instance-metadata-to-breach-your-app-in-aws/>
 - EC2 Instances sometimes need access to private assets like S3 buckets

- An IAM role with the necessary access will be assigned to the Instance
 - An access key will be issued to the instance
 - This key will be a part of the Instance Metadata
- Resource Exhaustion / DoS Attacks
 - Direct-to-Origin Attacks
 - DDoS attack
 - Bypasses CDN protections
 - Accomplished by discovering the Origin Server IP or by requesting non-existent resource
- Cloud Malware Injection Attacks
 - Attacker creates a malicious service/app/image
 - Attacker uploads malware to cloud service provider
 - Malware image is now trusted by CSP
 - Attacker can now use Malware Image to perform attacks such as
 - DoS
 - MitM
- Side-Channel Attacks
 - Attack on cloud hardware
 - Shared hardware may allow attacker access to sensitive data
 - Storage devices
 - Reallocated space may have data remnants
- **Tools**
 - ScoutSuite
 - <https://github.com/nccgroup/ScoutSuite>
 - Maps attack surface of cloud service
 - CloudBrute
 - <https://github.com/0xsha/CloudBrute>
 - Brute-Force enumeration tool for cloud services
 - Pacu
 - <https://rhinosecuritylabs.com/aws/pacu-open-source-aws-exploitation-framework>
 - AWS Exploitation Framework
 - Cloud Custodian
 - <https://cloudcustodian.io/>
 - Cloud management system
 - Has functionality to audit for security compliance